Guide d'utilisation

AL-AFNA Risk Manager

Identifiez vos risques. Choisissez les bonnes protections.



Version 1.0 | Octobre 2026

Un outil en ligne pour repérer les risques de votre entreprise,
Choisir les protections adaptées et suivre vos progrès.

Auteur : Abdoul Aziz ADAMOU LOUCHÉ

Projet final GRC, Programme d'Excellence en Cybersécurité APSI-NE 2026

1. La plateforme en bref

AL-AFNA Risk Manager est un outil en ligne qui aide une PME à répondre à trois questions simples :

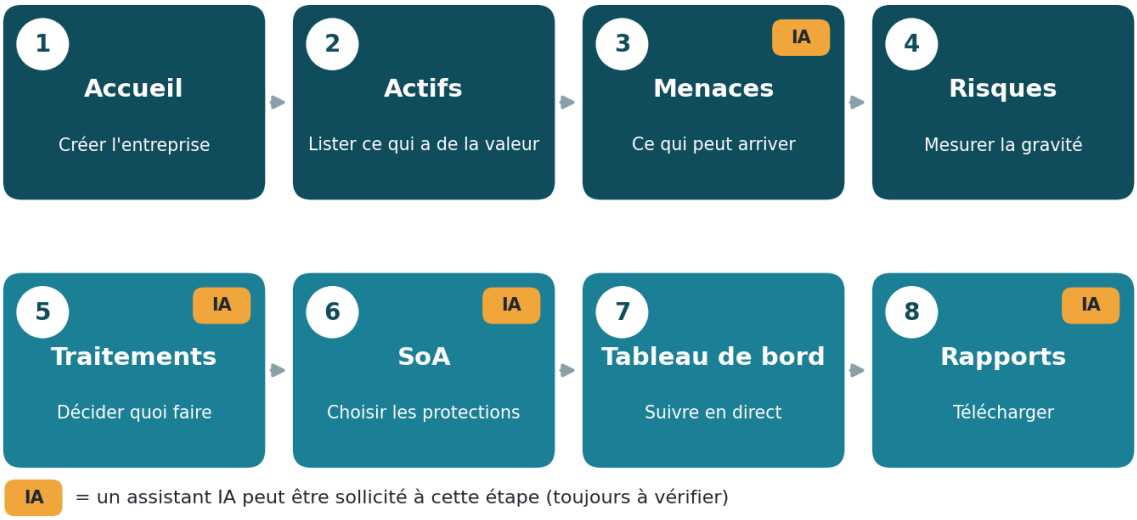
1. **Qu'est-ce que nous possédons** qui a de la valeur (serveurs, ordinateurs, données, applications) ?
2. **Qu'est-ce qui peut mal tourner** (piratage, panne, erreur, perte de données) et quelle est la gravité ?
3. **Quelles protections mettre en place** en priorité, et où en sommes-nous ?

L'outil s'appuie sur trois normes internationales : **ISO/IEC 27005** (méthode d'analyse des risques), **ISO/IEC 27001:2022** (système de management de la sécurité, dont l'Annexe A contient 93 mesures de protection) et **ISO/IEC 27002:2022** (guide de ces mesures).

Ce que l'outil fait : il vous guide pas à pas, calcule automatiquement le niveau de chaque risque, propose des mesures adaptées, suit votre avancement et produit des rapports prêts à présenter.

Ce qu'il ne fait pas : il ne remplace ni un audit ni une certification, et il ne décide pas à votre place; chaque proposition doit être validée par vous.

2. Le parcours en un coup d'œil



Suivez les pages dans cet ordre, de gauche à droite dans le menu.

Page	Ce que vous faites	IA ?
Accueil	Créer l'entreprise à évaluer	Non
Actifs	Lister ce qui a de la valeur et le noter	Non
Menaces	Décrire ce qui peut arriver et les faiblesses de chaque actif	Oui, suggestion de menace
Risques	Croiser actif, menace et faiblesse, puis mesurer la gravité	Non
Traitements	Décider quoi faire pour chaque risque	Oui, suggestion de mesure
SoA	Choisir les protections de l'Annexe A et suivre leur mise en œuvre	Aide à la demande

Page	Ce que vous faites	IA ?
Tableau de bord	Suivre 8 indicateurs en direct	Non
Rapports	Télécharger le rapport (PDF, Word, Excel)	Oui, synthèse

3. Le rôle de l'IA

L'IA est un **assistant**, jamais un décideur. Elle intervient à quatre endroits seulement :

- **Page Menaces :** le bouton « Suggérer une menace via IA » propose une menace plausible pour un actif choisi.
- **Page Traitements :** le bouton « Suggérer une mesure via IA » propose une option de traitement et une mesure.
- **Page SoA :** le panneau « Besoin d'aide pour décider ? » répond à vos questions (par exemple : cette mesure s'applique-t-elle à ce risque ?).
- **Page Rapports :** une synthèse rédigée pour la direction, que vous pouvez corriger.

La création de l'entreprise, les actifs, les risques et le tableau de bord n'utilisent pas l'IA. Les mesures recommandées sur la page SoA viennent de règles écrites et vérifiables, pas de l'IA.

Règles à retenir :

- Une suggestion de l'IA est **toujours à vérifier** avant d'enregistrer. Les champs se remplissent, mais rien n'est enregistré sans votre clic.
- Dans le panneau d'aide de la SoA, l'IA ne peut citer que les 93 mesures de la liste. Elle ne cite aucune loi ni aucun article. Si sa réponse sort de ce cadre, elle est écartée automatiquement : reformulez simplement votre question.
- Les textes envoyés à l'IA (noms d'actifs, de menaces, de vulnérabilités, niveaux, questions) transitent par un serveur sécurisé vers un service d'IA externe (Google Gemini).

4. Vocabulaire

Terme	Définition simple	Exemple
Contexte	L'entreprise évaluée, avec son périmètre et ses objectifs	AfriTech SARL, réseau du siège
Actif	Tout ce qui a de la valeur pour l'entreprise	Serveur ERP, base clients
Confidentialité (C)	Seules les personnes autorisées y accèdent	Fiches de paie
Intégrité (I)	L'information n'est pas modifiée par erreur ou malveillance	Comptabilité
Disponibilité (D)	L'information est accessible quand on en a besoin	Site de vente en ligne
Menace	Une cause possible d'incident	Accès non autorisé, panne électrique

Terme	Définition simple	Exemple
Vulnérabilité	Une faiblesse d'un actif que la menace peut exploiter	Mots de passe faibles
Risque	Une menace qui exploite la faiblesse d'un actif	Accès non autorisé au serveur ERP
Vraisemblance	À quel point le risque est probable (1 à 5)	4 : probable
Impact	La gravité des conséquences (1 à 5)	5 : très grave
Score	Vraisemblance multipliée par impact	4 × 5 = 20
Traitement	La décision prise face à un risque	Modifier, éviter, transférer, accepter
Mesure	Une protection de l'Annexe A d'ISO 27001	A.8.5 Authentification sécurisée
SoA	Déclaration d'applicabilité : la liste des 93 mesures avec, pour chacune, retenue ou non, pourquoi, et où vous en êtes	Mesure A.5.15 retenue, en cours

5. Avant de commencer : votre compte

1. Sur la page **Créer un compte**, saisissez votre adresse e-mail et un mot de passe de 6 caractères minimum, puis confirmez-le.
2. Si on vous le demande, ouvrez le message reçu et confirmez votre adresse (pensez à regarder les courriers indésirables).
3. Sur la page **Connexion**, entrez vos identifiants.
4. Le lien **Déconnexion** se trouve en haut à droite du menu.

Vos données sont privées : chaque compte ne voit que ses propres entreprises, actifs et risques.

> **Exemple fil rouge :** dans tout ce guide, nous évaluons une entreprise **fictive**, AfriTech SARL. Vous pouvez la reprendre telle quelle pour vous entraîner, ou inventer un autre cas fictif.

6. Démarrage rapide en 10 minutes

Reprenez l'exemple **AfriTech SARL** en recopiant les valeurs ci-dessous. Vous parcourrez toutes les étapes de l'outil en une dizaine de minutes. Utilisez uniquement des données fictives, comme dans cet exemple.

1. **Accueil (1 minute).** Nom : AfriTech SARL. Périmètre : réseau du siège social. Objectifs : identifier les risques prioritaires. Cliquez sur **Créer et commencer**.
2. **Actifs (2 minutes).** Ajoutez deux actifs. Premier actif : Serveur ERP, type Serveur, propriétaire Direction, C4, I4, D5. Second actif : Routeur principal, type Routeur / Switch, propriétaire Service IT, C3, I4, D4.
3. **Menaces et vulnérabilités (2 minutes).** Ajoutez la menace « Accès non autorisé », source externe (ou testez le bouton IA et relisez sa proposition). Puis ajoutez, pour le Serveur ERP, la vulnérabilité « Mots de passe faibles ».
4. **Risques (1 minute).** Choisissez l'actif Serveur ERP, la menace Accès non autorisé et la vulnérabilité Mots de passe faibles. Vraisemblance 4, impact 5. Cliquez sur **Calculer et enregistrer**. Résultat attendu : score 20, niveau Critique.

5. **Traitements (1 minute).** Choisissez ce risque. Option : Modifier. Mesure : A.8.5 Authentification sécurisée. Description : imposer des mots de passe robustes et une double vérification. Responsable : Service IT. Statut : En cours. Cliquez sur **Enregistrer le traitement**.
6. **SoA (2 minutes).** Dans l'onglet « Recommandées pour tes risques », lisez les mesures suggérées pour ce risque, puis cliquez sur **Confirmer ces mesures**. Ouvrez ensuite l'onglet « Toutes les mesures », cliquez sur A.8.5, passez l'état à « En place » et écrivez comme preuve : double vérification activée. Cliquez sur **Enregistrer la mesure**.
7. **Tableau de bord (30 secondes).** Observez les cartes. Cliquez sur une carte pour voir son détail, puis sur le bouton **i** pour lire sa fiche.
8. **Rapports (30 secondes).** Téléchargez le **rapport d'audit en PDF** et ouvrez-le.

À la fin, vous devez voir : le risque critique marqué comme traité, 15 mesures retenues sur 93 dans la SoA, et un rapport PDF avec la page de garde au nom d'AfriTech SARL.

> **Astuce.** Si un champ vous bloque, reportez-vous à la section correspondante du guide, juste après. Chaque page y est détaillée.

7. Guide page par page

> **Astuce générale :** en haut de chaque page, le menu « **Contexte d'évaluation actif** » indique l'entreprise sur laquelle vous travaillez. Si vous ne voyez pas vos données, vérifiez d'abord que la bonne entreprise est choisie.

7.1 Accueil : créer l'entreprise

À quoi ça sert. C'est le point de départ. Chaque évaluation commence par la création d'une entreprise.

Ce que vous voyez

- Un bandeau qui confirme la connexion à la base de données.
- Le formulaire **Nouvelle entreprise à évaluer**.
- Un graphique de la **répartition des risques par niveau** et une **matrice des risques** (5 × 5). Chaque case indique combien de risques ont cette vraisemblance et cet impact, et le survol affiche le détail.
- Le tableau **Entreprises déjà évaluées**, avec le nombre d'actifs, de risques et de traitements.

Comment faire

1. Saisissez le **nom de l'entreprise** (obligatoire).
2. Précisez le **périmètre** : ce qui est évalué (un site, un réseau, un service).
3. Indiquez les **objectifs** de l'évaluation.
4. Cliquez sur **Créer et commencer**. Vous arrivez sur la page Actifs.

> **Exemple.** Nom : AfriTech SARL. Périmètre : réseau du siège social. Objectifs : identifier les risques prioritaires avant une certification.

Dans le tableau : Ouvrir reprend le travail sur une entreprise, **Modifier** change son nom ou son périmètre, **Supprimer** efface l'entreprise **et tous ses actifs, risques et traitements. C'est irréversible.**

7.2 Actifs : recenser ce qui a de la valeur

À quoi ça sert. Vous ne pouvez protéger que ce que vous avez listé. Chaque actif est noté selon trois critères.

Les champs

- **Nom de l'actif** : ce que c'est (Serveur ERP).
- **Type** : Serveur, Poste de travail, Routeur / Switch, Application, Donnée ou Autre.
- **Propriétaire / service** : qui en est responsable.
- **Confidentialité, Intégrité, Disponibilité** : une note de 1 (peu important) à 5 (vital). La valeur par défaut est 3.

Comment faire. Remplissez le formulaire, cliquez sur **Enregistrer l'actif**. Il apparaît dans la liste avec des pastilles C, I et D. Pour retirer un actif, cliquez sur **Supprimer**.

> **Exemple.** Serveur ERP, type Serveur, propriétaire Direction, C4, I4, D5 (l'entreprise ne peut pas fonctionner s'il est arrêté).

> **Astuce.** Commencez par 3 à 5 actifs essentiels. Vous pourrez en ajouter ensuite.

7.3 Menaces et vulnérabilités : ce qui peut arriver, et par où

À quoi ça sert. Cette page a deux parties.

Partie 1 : les menaces. Elles forment une **bibliothèque réutilisable** : une même menace peut servir pour plusieurs actifs.

- **Nom**, **Description** et **Source** (interne, externe ou environnementale).
- **Rôle de l'IA :** choisissez un actif dans « Suggérer à partir d'un actif », puis cliquez sur **Suggérer une menace via IA**. Le formulaire se remplit. **Relisez, corrigez si besoin, puis cliquez sur Ajouter la menace.**

Partie 2 : les vulnérabilités. Elles sont toujours **liées à un actif précis**.

- Choisissez l'**actif concerné**, donnez un **nom** et une **description**, puis **Ajouter la vulnérabilité**.

> **Exemple.** Menace : accès non autorisé (source externe). Vulnérabilité sur le Serveur ERP : mots de passe faibles.

> **Astuce.** Une vulnérabilité décrit une faiblesse, pas un incident. « Mots de passe faibles » est une vulnérabilité ; « piratage » est une menace.

7.4 Risques : mesurer la gravité

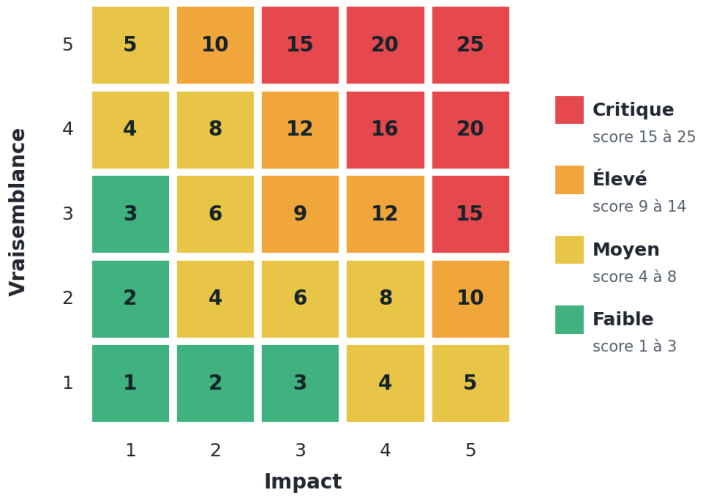
À quoi ça sert. Un risque se lit comme une phrase : *une menace exploite la faiblesse d'un actif.* Cette page combine les trois et calcule la gravité.

Comment faire

1. Choisissez l'**actif**, la **menace** et, si vous le souhaitez, la **vulnérabilité**.
2. Donnez la **vraisemblance** (1 à 5) et l'**impact** (1 à 5).
3. Cliquez sur **Calculer et enregistrer**.

Le calcul est automatique : score = vraisemblance × impact, de 1 à 25. Le niveau en découle :

Score	Niveau
15 à 25	Critique
9 à 14	Élevé
4 à 8	Moyen
1 à 3	Faible



> **Exemple.** Serveur ERP, accès non autorisé, mots de passe faibles. Vraisemblance 4, impact 5. Score 20, niveau **Critique**.

Les risques sont triés du plus grave au moins grave : traitez d'abord ceux du haut.

7.5 Traitements : décider quoi faire

À quoi ça sert. Pour chaque risque, vous choisissez une réponse. Seuls les risques **sans traitement** sont proposés dans la liste.

Les quatre options

Option	Signification	Exemple
Modifier	Réduire la vraisemblance ou l'impact	Renforcer les mots de passe
Éviter	Supprimer la cause du risque	Retirer le service concerné
Transférer	Partager le risque	Assurance, sous-traitance
Accepter	Juger le risque tolérable	Risque faible, coût de protection trop élevé

Comment faire

1. Choisissez le **risque**.
2. (Optionnel) **Rôle de l'IA :** cliquez sur **Suggérer une mesure via IA** pour préremplir l'option, la mesure et sa description. Vérifiez-les.
3. Remplissez l'**option**, la **mesure ISO 27002** (code et intitulé), la **description**, le **responsable** et le **statut** (Prévu, En cours, Terminé).
4. Cliquez sur **Enregistrer le traitement**.

> **Exemple.** Option : Modifier. Mesure : A.8.5 Authentification sécurisée. Description : imposer des mots de passe robustes et une double vérification. Responsable : service IT. Statut : En cours.

7.6 SoA : choisir les protections et suivre leur mise en œuvre

À quoi ça sert. La déclaration d'applicabilité (SoA) liste les 93 mesures de l'Annexe A d'ISO 27001. Pour chacune, vous indiquez si elle s'applique à votre entreprise, pourquoi, et où vous en êtes. La page propose deux onglets.

Onglet « Recommandées pour tes risques » (affiché par défaut)

- Un **résumé** de l'entreprise : actifs, menaces, vulnérabilités, risques par niveau, risques traités, mesures retenues.
- Une **carte par risque**, avec les mesures suggérées et la raison de chaque suggestion. Ces suggestions viennent de règles écrites, pas de l'IA.
- **Si les mesures conviennent :** cliquez sur **Confirmer ces mesures**. Le lien entre le risque et les mesures est créé et la SoA se préremplit.
- **Sinon :** cliquez sur **Non, je choisis moi-même**. La liste des 93 mesures s'ouvre, par thème, avec un filtre. Cochez celles qui conviennent, puis **Valider ma sélection**.
- **Modifier** permet de revenir sur un choix. **Demander à l'IA** pose une question sur ce risque.

Onglet « Toutes les mesures (93) »

- La liste complète, avec recherche et filtres (thème, statut).
- Cliquez sur une mesure pour renseigner : **applicabilité** (non évalué, applicable, non applicable), **justification** (obligatoire si non applicable), **état de mise en œuvre** (non évalué, non commencé, partiel, en place), **écart constaté**, **responsable** et **preuve**.
- Cochez les **risques couverts** par cette mesure.
- Une **barre d'avancement** indique combien de mesures sont évaluées sur 93. **Exporter en CSV** télécharge la SoA.

Panneau « Besoin d'aide pour décider ? » (rôle de l'IA)

- Choisissez un risque et/ou une mesure, cliquez sur une question type ou écrivez la vôtre, puis **Poser la question**.
- La réponse est un conseil, **à vérifier**. Elle ne remplit rien à votre place.

> **Exemple.** Pour le risque « Serveur ERP, accès non autorisé », l'outil suggère A.5.15 (contrôle d'accès), A.5.18 (droits d'accès), A.8.2 (droits privilégiés), A.8.3 (restriction d'accès) et A.8.5 (authentification sécurisée). Vous confirmez. Dans l'autre onglet, vous passez A.8.5 à « En place » et indiquez comme preuve « double vérification activée le 15 octobre ».

7.7 Tableau de bord : suivre l'avancement en direct

À quoi ça sert. Huit indicateurs calculés en direct sur l'entreprise choisie. La bordure de chaque carte est **verte, orange ou rouge** selon des seuils.

Indicateur	Ce qu'il dit
Répartition par niveau	Combien de risques critiques, élevés, moyens, faibles
Risques critiques ou élevés non traités	Les urgences à traiter

Indicateur	Ce qu'il dit
Taux de risques traités	La part des risques ayant un traitement
Mesures évaluées	La part des 93 mesures examinées
Taux de mise en œuvre	Les mesures applicables déjà en place
Écart de mise en œuvre	Les mesures applicables non commencées
Risques sans mesure associée	Les risques non reliés à une protection
Actifs les plus exposés	Les actifs concentrant le plus de risques

Comment l'utiliser

- **Cliquez sur une carte** (ou sur une barre) : le détail s'affiche dessous, par exemple la liste des risques critiques non traités.
- **Cliquez sur le bouton i** : la fiche de l'indicateur donne sa formule, sa source et ses seuils.
- **Exporter les fiches (CSV)** télécharge le tableau des indicateurs.

> **Exemple.** La carte « Risques critiques ou élevés non traités » est rouge et indique 2. Vous cliquez, vous voyez les deux risques, vous allez les traiter, et la carte passe au vert.

7.8 Rapports : obtenir vos documents

À quoi ça sert. Produire des documents propres à remettre à la direction, à un auditeur ou à un client.

Deux documents, trois formats

- Le **rapport d'audit** : page de garde au nom de l'entreprise, contexte et périmètre, synthèse, inventaire des actifs, répartition et registre des risques, déclaration d'applicabilité et traçabilité entre risques et mesures.
- Le **document de recommandations** : le plan de traitement des risques.
- Formats : **PDF**, **Word** (modifiable) et **Excel** (une feuille par section).

Comment faire

1. Choisissez l'entreprise dans le menu du haut.
2. (Optionnel) **Rôle de l'IA :** générez la **synthèse managériale**, puis relisez et corrigez le texte. Il apparaît dans le rapport d'audit.
3. Cliquez sur le bouton du document et du format voulus : le fichier se télécharge.

> **Exemple.** Pour AfriTech SARL, choisissez l'entreprise, puis cliquez sur le rapport d'audit en PDF. Le document obtenu porte une page de garde au nom d'AfriTech SARL, le registre avec le risque critique sur le Serveur ERP, et la mesure A.8.5 dans la déclaration d'applicabilité.

> **Astuce.** Les sections SoA et traçabilité n'apparaissent que si vous avez renseigné la SoA. Faites-le avant de générer le rapport.

8. Questions fréquentes

Je ne vois pas mes données. Vérifiez le menu « Contexte d'évaluation actif » en haut de la page : c'est peut-être une autre entreprise.

Je me suis trompé dans un actif ou un risque. Supprimez la ligne avec **Supprimer**, puis recréez-la correctement.

La liste des risques de la page Traitements est vide. Soit aucun risque n'existe, soit tous sont déjà traités : le message l'indique.

L'IA affiche une erreur ou ne répond pas. Patientez quelques secondes et réessayez, ou reformulez la question. Vous pouvez toujours remplir les champs à la main.

Le panneau d'aide a écarté ma réponse. C'est le contrôle de sécurité : la réponse citait une référence introuvable dans la liste. Reformulez votre question.

Que faire si j'oublie mon mot de passe ? La réinitialisation n'est pas encore disponible. Contactez la personne qui vous a donné l'accès.

9. Confidentialité et bonnes pratiques

- **Données :** saisissez **uniquement des données fictives**. N'entrez jamais d'informations réelles de votre organisation, ni de mots de passe, d'adresses IP internes ou de données personnelles.
- **Hébergement :** vos données sont stockées dans une base Supabase.
- **Ce qui est envoyé à l'IA :** quand vous utilisez l'assistance IA, les noms d'actifs, de menaces et de vulnérabilités, les niveaux de risque, le nom de l'organisation, le nombre d'actifs et de risques, et vos questions sont envoyés au service Google Gemini par un serveur sécurisé. La clé de ce service n'est jamais visible dans votre navigateur.
- **Isolation :** chaque compte ne voit que ses données. L'administrateur de la plateforme peut consulter des statistiques d'usage (nombre d'éléments créés, dates de connexion), jamais le contenu de vos données.
- **Validation :** l'outil aide à décider, vous restez responsable de vos choix. Relisez toujours les suggestions, surtout celles de l'IA.
- **Votre avis compte :** si un terme est obscur ou si une étape vous bloque, notez-le. Vos retours servent à améliorer l'outil.